

Delta Advanced Trucking, Inc.

Password & Authentication Policy

Policy Number: DAT-IT-007	Version: 2.0	Effective Date: December 12, 2025	Classification: Internal
Owner: IT Security	Approver: CEO	Review Cycle: Annual	Next Review: December 12, 2026

Table of Contents

2. Scope	3
3. Definitions	3
4. Password Requirements	4
5. Multi-Factor Authentication (MFA) Requirements	6
6. Password Management	7
7. Account Lockout & Brute Force Protection	8
8. Single Sign-On (SSO)	8
9. Privileged Access Management (PAM)	9
10. Vendor & Third-Party Authentication	9
11. Incident Response for Compromised Credentials	9
12. Compliance	10
13. Enforcement	10
14. Policy Review	10

15. Approval & Signature	11

Quick Reference: Password Requirements by Account Type

Use this table as a fast reference. Full requirements are defined in Section 4.

Account Type	Min. Length	Complexity	Rotation	Storage	MFA Required
Standard User	14 characters <i>or 20+ char passphrase</i>	Upper, lower, number, special character	Upon compromise or policy prompt; no forced periodic expiry	Approved password manager	Situationally required (see §5)
Privileged / Admin	16 characters	Upper, lower, number, special character	Every 90 days or upon suspected compromise	PAM solution only	Always required
Service Account	20 characters	Maximum complexity; randomly generated	Annually or upon personnel change	Approved secrets management system only	N/A (non-interactive)
ELD / Fleet System	14 characters (user); 16 characters (admin)	Unique per driver/user; default passwords changed at deployment	Admin accounts: every 90 days	Approved password manager or PAM	Admin access: always required

1. Purpose

This policy establishes strong, modern authentication standards to protect all Delta Advanced Trucking, Inc. (DAT) systems, applications, and data from unauthorized access. Weak or compromised credentials remain one of the leading causes of security incidents across the transportation and logistics sector. This policy aligns

with the National Institute of Standards and Technology (NIST) Special Publication 800-63B Digital Identity Guidelines and adopts a length-first, breach-aware approach to credential management.

The objectives of this policy are to:

- Establish clear, enforceable minimum requirements for passwords and authentication across all account types;
- Mandate multi-factor authentication (MFA) for high-risk access scenarios;
- Support a secure and usable authentication experience for all users, including drivers, dispatchers, and corporate staff;
- Reduce the organization's exposure to credential-based attacks, including credential stuffing and brute-force attempts; and
- Maintain compliance with applicable regulatory and industry frameworks.

2. Scope

This policy applies to **all individuals** who access Delta Advanced Trucking, Inc. systems or data, including but not limited to:

- Full-time and part-time employees (corporate, field, and driving staff);
- Contractors, consultants, and temporary workers;
- Vendors and third-party service providers with any level of system access.

This policy covers **all systems, platforms, and devices** owned, leased, or operated by Delta Advanced Trucking, Inc., including:

- Corporate workstations, laptops, and mobile devices;
- Fleet management systems and telematics platforms;
- Electronic Logging Device (ELD) portals and driver-facing applications;
- Dispatch and load management platforms;
- Cloud services and SaaS applications (including Microsoft 365 and fleet cloud portals);

- Financial and HR information systems;
- Network infrastructure, routers, switches, and VPN systems; and
- Any third-party system accessed using DAT credentials.

3. Definitions

Term	Definition
Password	A secret character string used to authenticate a user's identity to a system or application.
Passphrase	A sequence of four or more random, unrelated words used as a password. Passphrases are typically longer and more memorable than traditional passwords. Example format: <i>correct-horse-battery-staple</i> (for illustration only; do not use this specific example).
MFA / 2FA	Multi-Factor Authentication (MFA), also called Two-Factor Authentication (2FA), requires users to verify their identity using two or more independent factors: something you know (password), something you have (authenticator device), or something you are (biometric).
SSO	Single Sign-On — an authentication method that allows a user to access multiple applications with one set of login credentials and a single authentication session.
Privileged Account	An account with elevated permissions beyond those of a standard user, including system administrator, network administrator, database administrator, or security administrator accounts.
Service Account	A non-interactive account used by an application, script, or automated process to authenticate to a system or service. Service accounts are not intended for direct human login.
Password Manager	An approved software application that securely stores, encrypts, and manages passwords and other credentials on behalf of a user or organization.

Term	Definition
Credential Stuffing	A cyberattack in which stolen username/password combinations from one breach are automatically tested against other services, exploiting users who reuse passwords.
Brute Force Attack	An attack method in which automated tools systematically attempt every possible password combination until the correct one is found.
PAM	Privileged Access Management — a solution that controls, monitors, and audits access by privileged users to critical systems and sensitive data.

4. Password Requirements

All passwords used to access Delta Advanced Trucking systems must meet the minimum requirements defined below. Requirements vary by account type. In all cases, DAT aligns with NIST SP 800-63B guidance, prioritizing password length and checking credentials against known breached password lists rather than mandating arbitrary complexity rules alone.

NIST Alignment Note

Per NIST SP 800-63B, DAT does not mandate periodic password changes for standard user accounts unless a breach or compromise is suspected. Longer passwords and passphrases are preferred over short, complex passwords that are difficult to remember and lead to poor security behaviors.

4.1 Standard User Accounts

Standard user accounts include all employee, contractor, and vendor accounts that do not carry administrative or privileged permissions.

- **Minimum Length:** 14 characters.

- **Passphrase Option:** A passphrase consisting of four or more random, unrelated words totaling 20 or more characters is an acceptable alternative and is encouraged for memorability.
- **Character Composition:** Passwords must include at least one uppercase letter, one lowercase letter, one number, and one special character (e.g., !, @, #, \$, %).
- **Password Reuse:** Users may not reuse any of their last 12 passwords.
- **Prohibited Patterns:** Passwords must not contain the user's username, employee ID, the company name ("Delta," "DAT," "Trucking"), or common dictionary words used as the entire password.
- **Breached Password Screening:** Systems must, where technically feasible, check new passwords against known compromised credential databases (e.g., Have I Been Pwned corpus) and reject any matches.
- **Expiry:** No mandatory periodic expiration. Passwords must be changed immediately upon any suspected or confirmed compromise.

4.2 Privileged / Administrator Accounts

Privileged accounts include all system administrator, network administrator, database administrator, and security operations accounts.

- **Minimum Length:** 16 characters.
- **Character Composition:** Must include uppercase, lowercase, numbers, and special characters.
- **Account Separation:** Privileged account passwords must be entirely separate from the same user's standard account credentials. No shared or similar passwords between account types.
- **Storage:** All privileged account credentials must be stored exclusively within the company-approved Privileged Access Management (PAM) solution. Storage outside the PAM system is prohibited.

- **Rotation:** Privileged account passwords must be rotated every 90 days, or immediately upon any suspected compromise or upon the departure of any personnel with knowledge of the credentials.
- **MFA:** MFA is mandatory for all privileged account access. See Section 5.

4.3 Service Accounts

Service accounts are used by applications, automation scripts, and scheduled tasks to authenticate to DAT systems.

- **Minimum Length:** 20 characters, randomly generated.
- **Complexity:** Maximum available complexity; passwords must be machine-generated, not human-chosen.
- **Storage:** Service account credentials must be stored only in the company-approved secrets management system (e.g., HashiCorp Vault or equivalent). Storage in scripts, source code, configuration files, or shared drives is strictly prohibited.
- **Rotation:** Service account passwords must be rotated at least annually. Immediate rotation is required upon any personnel change where the credential may have been known to a departing individual, or upon any suspected compromise.
- **Documentation:** All service accounts must be documented in the IT asset register with an identified business owner and a stated purpose.

4.4 ELD and Fleet System Credentials

Electronic Logging Devices (ELDs), telematics portals, and fleet management platforms present unique operational requirements and must be managed accordingly.

- **Unique Credentials:** Every driver and user must have a unique username and password. Shared or generic login accounts are prohibited.
- **Default Password Change:** All manufacturer-set default passwords on ELD devices, telematics units, and fleet portals must be changed immediately at

the time of deployment. Default credentials must never be used in production.

- **Driver/User Accounts:** Must meet the standard user account requirements in Section 4.1 (minimum 14 characters).
- **Fleet System Admin Accounts:** Must meet the privileged account requirements in Section 4.2 (minimum 16 characters, managed in PAM, rotated every 90 days).
- **Offboarding:** Driver and fleet portal credentials must be disabled or removed within 24 hours of a driver or contractor departure.

Prohibited — Default Credentials

Using factory-default or manufacturer-provided credentials on any device or system connected to the Delta Advanced Trucking network is a serious security violation and may result in disciplinary action. IT must verify credential changes during device commissioning.

5. Multi-Factor Authentication (MFA) Requirements

Multi-Factor Authentication adds a critical second layer of protection beyond the password alone. DAT mandates MFA for all high-risk access scenarios and strongly recommends its use for all system access where supported.

5.1 MFA Is Mandatory For:

- All remote access to DAT systems, including VPN connections and Remote Desktop Protocol (RDP) sessions;
- All cloud platform access, including Microsoft 365 (email, SharePoint, Teams), fleet management cloud portals, and any SaaS application storing DAT data;
- All privileged account actions, including administrative logins and elevated permission use;
- All email access from outside the corporate network; and

- All access to financial systems, HR platforms, and payroll applications.

5.2 Approved MFA Methods

The following MFA methods are approved for use, listed in order of preference from most secure to least secure:

Preference	Method	Description	Status
1 (Preferred)	Hardware Security Key (FIDO2 / WebAuthn)	Physical device (e.g., YubiKey) plugged into or tapped against the authenticating device. Phishing-resistant.	APPROVED
2	Authenticator App (TOTP)	Time-based one-time password generated by an approved app (e.g., Microsoft Authenticator, Google Authenticator). Must be installed on a company-managed or registered personal device.	APPROVED
3	Push Notification App	Approve/deny push notification sent to an enrolled authenticator application. Requires the user to verify request context before approving.	APPROVED
4 (Least Preferred)	SMS One-Time Password (OTP)	A one-time code delivered via SMS text message. Permitted where no higher-assurance method is available. SIM-swap attacks present a risk; use of stronger methods is strongly encouraged.	PERMITTED

5.3 Prohibited MFA Practices

- **Security Questions:** Knowledge-based security questions (e.g., "What is your mother's maiden name?") are not permitted as a second authentication factor under any circumstances.
- **"Remember This Device" Exemptions:** Persistent device trust exemptions from MFA require explicit IT Security approval. Approved exemptions are limited to a maximum of 30 days, after which re-enrollment is required.
- **MFA Fatigue:** Users must never approve an MFA push notification they did not personally initiate. Unexpected MFA prompts must be denied and reported to the IT Help Desk immediately.

⚠ **MFA Push Fatigue Warning**

If you receive an unexpected authentication request or push notification that you did not initiate, **deny it immediately** and contact the IT Help Desk. This may indicate an active attack on your account.

6. Password Management

6.1 Password Manager Usage

Use of a company-approved password manager is **required** for all IT staff and system administrators, and is **strongly recommended** for all employees. Password managers allow users to maintain unique, complex passwords for every system without the need to memorize them. IT Security will maintain and communicate the current list of approved password manager tools.

6.2 Prohibited Password Behaviors

The following behaviors are strictly prohibited and may result in disciplinary action:

- Writing passwords on paper, sticky notes, whiteboards, or any physical medium;

- Storing passwords in unencrypted text files, spreadsheets, email drafts, or notes applications;
- Sharing passwords via email, chat, SMS, phone, or any other communication channel;
- Reusing company system passwords for personal accounts (e.g., personal email, social media, online shopping);
- Sharing login credentials with colleagues, managers, or IT staff — even temporarily; and
- Using auto-complete or browser-saved passwords for privileged or sensitive system accounts (approved password managers are the correct alternative).

! Credential Sharing Is Never Acceptable

No legitimate IT or security team member will ever ask for your password. If anyone — including someone claiming to be from IT — requests your password, deny the request and report it to IT Security immediately.

6.3 Password Reset Process

Reset Scenario	Process	Authorization Required
Self-Service Reset	User initiates reset via the MFA-verified self-service password reset portal. New password must meet all policy requirements.	MFA verification by the requesting user
IT Help Desk Reset	User contacts IT Help Desk. Identity must be confirmed via employee ID, manager verification, or other approved identity confirmation method before any reset is performed.	Identity confirmation required; no password resets without verification
Emergency Reset	For locked or compromised accounts requiring urgent access restoration. Initiated through the incident response process.	Direct manager authorization required; IT Security notified

7. Account Lockout & Brute Force Protection

All DAT systems must implement account lockout controls to mitigate brute force and automated credential-stuffing attacks. The following minimum standards apply:

Control	Standard Setting	Notes
Lockout Threshold	10 consecutive failed login attempts	Counter resets upon successful login
Lockout Duration	15 minutes (auto-unlock)	Or manual unlock by IT Help Desk upon identity verification
CAPTCHA Trigger	After 5 consecutive failed attempts (where platform supports it)	Applied to web-facing login portals and ELD portals
Alerting	IT Security alerted on accounts with 10+ failed attempts within a 60-minute window	Logged in SIEM; reviewed for potential attack patterns
Privileged Account Lockout	5 consecutive failed login attempts	Manual IT Security unlock required; incident ticket opened automatically

8. Single Sign-On (SSO)

Delta Advanced Trucking implements Single Sign-On (SSO) to streamline access to approved internal applications while maintaining strong authentication controls. The following standards govern SSO use:

- **Approved Applications:** SSO is enabled for applications explicitly approved and configured by IT Security. Applications not integrated with DAT's SSO platform require separate credential management per this policy.
- **MFA Not Replaced:** SSO authentication does not replace or bypass MFA requirements. MFA is enforced at the SSO identity provider level, ensuring a single MFA challenge protects access to all connected applications.

- **Session Timeout:** SSO sessions expire after a maximum of 8 hours of activity. Users must re-authenticate after session expiry.
- **Idle Timeout:** SSO sessions inactive for 30 minutes will prompt for re-authentication.
- **Risk-Based Authentication:** The SSO platform may require step-up authentication (re-prompting for MFA) when an unusual access pattern is detected, such as access from an unrecognized location or device.
- **Prohibited:** Users must not share SSO sessions or leave authenticated workstations unattended without locking the screen.

9. Privileged Access Management (PAM)

All privileged accounts and elevated-permission access at Delta Advanced Trucking must be managed through the company's approved PAM solution. The following requirements apply:

- **Centralized Management:** All privileged account credentials are stored, rotated, and audited exclusively within the PAM platform. No privileged credentials may exist outside the PAM system.
- **Just-in-Time (JIT) Access:** Where supported by the PAM solution, privileged access is provisioned on a just-in-time basis — granting elevated access only for the duration of a specific approved task, then revoking it automatically.
- **Session Recording:** All privileged sessions initiated through the PAM solution must be recorded and logged. Session recordings are retained for a minimum of 12 months and are available for security review and incident investigation.
- **Quarterly Access Review:** IT Security and department managers must conduct a formal review of all privileged accounts every 90 days. Accounts that are no longer required must be disabled or removed within 5 business days of the review.

- **No Shared Admin Accounts:** Generic or shared administrator accounts (e.g., "admin," "sysadmin") are prohibited. Every privileged action must be attributable to an individually named account.

10. Vendor & Third-Party Authentication

Third-party vendors and contractors who require access to Delta Advanced Trucking systems are subject to all applicable provisions of this policy, including the following specific requirements:

- **Unique Accounts:** Vendors must use individually assigned accounts. Shared vendor accounts are prohibited. Each vendor representative requiring access must have a uniquely identified credential.
- **MFA Required:** MFA is mandatory for all vendor remote access to DAT systems, without exception.
- **Time-Limited Access:** Vendor access must be provisioned with a defined expiration date that corresponds to the term of engagement. Standing or indefinite vendor access is prohibited without documented justification and IT Security approval.
- **Monthly Review:** IT Security must review all active vendor accounts monthly during active engagements to confirm access remains necessary and appropriately scoped.
- **Immediate Revocation:** Vendor access must be revoked within 24 hours of engagement termination, personnel change at the vendor, or any security concern.
- **Least Privilege:** Vendor accounts must be provisioned with the minimum permissions necessary to perform the defined scope of work. Broad or unrestricted access is not permitted.

11. Incident Response for Compromised Credentials

When a password compromise is suspected or confirmed, a rapid and structured response is essential to limiting potential damage. The following process must be followed:

Step	Action	Responsible Party	Timeline
1	Immediately change the compromised password on all affected systems. If MFA is enabled, review and revoke any active sessions.	Affected user, with IT Help Desk assistance	Immediately upon discovery
2	Notify IT Security of the suspected or confirmed compromise, providing details of the affected account(s), systems, and circumstances.	Affected user or manager	Within 1 hour of discovery
3	IT Security investigates the scope of potential unauthorized access, reviews access logs, and determines whether data or systems were accessed without authorization.	IT Security team	Within 4 hours of notification
4	If unauthorized access to sensitive data or systems is confirmed, escalate to the Incident Response process and notify appropriate stakeholders per the DAT Incident Response Policy.	IT Security / CISO	As required by incident severity
5	Document incident findings, root cause, and remediation actions taken. Update security	IT Security	Within 5 business days of closure

Step	Action	Responsible Party	Timeline
	controls as appropriate.		

Reporting Contacts

Report suspected credential compromises to the IT Help Desk (internal ticketing system) or directly to IT Security. Incidents involving privileged accounts must be escalated directly to IT Security leadership. Do not delay reporting out of uncertainty — report and investigate.

12. Compliance

This policy is designed to align Delta Advanced Trucking, Inc. with the following recognized standards and frameworks. Compliance with this policy contributes directly to the organization's overall security posture and audit readiness.

Standard / Framework	Relevance to This Policy
NIST SP 800-63B — Digital Identity Guidelines	Primary technical standard for password length, complexity, breached password screening, and phishing-resistant MFA. Sections 4 and 5 of this policy are directly aligned.
CIS Controls (v8)	Control 5 (Account Management) and Control 6 (Access Control Management) inform account provisioning, privileged access management, and MFA requirements.
SOC 2 (Trust Services Criteria)	Logical access controls, credential management, and MFA requirements support CC6.1 and CC6.2 criteria for security and availability.
FMCSA Regulations	ELD and driver portal security requirements support compliance with FMCSA ELD mandate data integrity and access control provisions.

Compliance with this policy is monitored through periodic technical audits, access reviews, and vulnerability assessments conducted by IT Security. Identified gaps must be remediated within the timeframes specified in audit findings.

13. Enforcement

All employees, contractors, and third-party users are expected to understand and comply with this policy. Compliance is not optional. The following principles govern enforcement:

- **Technical Enforcement:** Where technically feasible, policy requirements will be enforced automatically through system configuration (e.g., password complexity rules, account lockout settings, MFA enforcement). Technical controls take precedence over individual judgment.
- **Non-Compliance Consequences:** Violations of this policy may result in disciplinary action up to and including termination of employment or termination of contract, depending on the severity and intent of the violation. Violations that result in a security incident may trigger additional legal or regulatory consequences.
- **Reporting:** Employees who are aware of policy violations must report them to IT Security or their manager. Good-faith reports of suspected violations will not result in retaliation.
- **Exceptions:** Exceptions to any requirement of this policy must be formally requested in writing to IT Security, approved by the CISO or designee, documented, and reviewed at least annually.

14. Policy Review

This policy will be reviewed on an **annual basis** by the IT Security team, or sooner in the event of:

- A significant security incident involving compromised credentials;
- Material changes to the regulatory or compliance landscape affecting DAT;

- Introduction of new systems, platforms, or authentication technologies; or
- Updated guidance from NIST, CIS, or other governing bodies.

Proposed revisions to this policy must be reviewed by IT Security and approved by the Chief Executive Officer prior to publication. All revisions will be tracked in the document version history below.

Version History

Version	Date	Author	Summary of Changes
1.0	March 15, 2023	IT Security	Initial policy release.
2.0	December 12, 2025	IT Security	Major revision: aligned with NIST SP 800-63B; added passphrase option; removed mandatory periodic expiry for standard accounts; expanded MFA requirements; added PAM, SSO, ELD, and vendor sections; added quick reference table.

15. Approval & Signature

By signing below, the undersigned approves this policy as an official governing document of Delta Advanced Trucking, Inc., effective as of the date indicated, and acknowledges responsibility for its communication and enforcement throughout the organization.

L. Thomas Marchland

L. Thomas Marchland

Chief Executive Officer
Delta Advanced Trucking, Inc.

Date: December 12, 2025

Delta Advanced Trucking, Inc. | DAT-IT-007 | Version 2.0 | Effective December
12, 2025 | Classification: Internal | IT Security